Міністерство освіти та науки України
Національний технічний університет України
«Київський політехнічний інститут імені Ігоря Сікорського»
Факультет інформатики та обчислювальної техніки
Кафедра інформатики та програмної інженерії

ЗВІТ

з дисципліни «Безпека програмного забезпечення»

лабораторна робота №1

ПОБУДОВА МОДЕЛІ ЗАГРОЗ ПРОГРАМНОГО ЗАСТОСУНКУ

Виконав:

Студент IV курсу
гр. ІП-31
Сатиренко П. Ю.

Перевірив:
викладач Соколовський В. В.

2026

Лабораторна робота №1.

Побудова моделі загроз програмного застосунку.

Тема: Побудова моделі загроз програмного застосунку.

Мета: Набути практичних навичок аналізу захищеності програмного застосунку через побудову моделі загроз, кількісне оцінювання виявлених загроз за CVSS та обґрунтоване планування контрзаходів.

Індивідуальне завдання.

1. Описати активи заданої системи та побудувати діаграму потоків даних (DFD) із позначенням меж довіри.

2. Застосувати методологію STRIDE до кожного елемента діаграми й скласти перелік щонайменше з 12 загроз.

3. Оцінити кожну загрозу за метрикою CVSS v3.1 та визначити щонайменше 3 загрози високого ризику.

4. Побудувати дерево атак для найкритичнішої загрози.

5. Сформувати реєстр ризиків із рішенням щодо кожного ризику та переліком контрзаходів.

6. Провести аналіз отриманих результатів та зробити висновки.

Варіант 18.

Платформа онлайн-курсів із перевіркою завдань. Пріоритетна категорія STRIDE – відмова від авторства (Repudiation).

Виконання роботи.

Для виконання лабораторної роботи було обрано навчальну систему відповідно до варіанта 18 – платформу онлайн-курсів із перевіркою завдань. Основними користувачами системи є студенти та викладачі. Студенти переглядають завдання, завантажують файли розв'язків або надсилають посилання на git-репозиторії, отримують автоматичні результати тестування та фінальні оцінки. Викладачі публікують умови робіт, налаштовують дедлайни, завантажують відкриті й закриті тестові набори, здійснюють ручну перевірку коду

та виставляють бали. Автоматична перевірка коду студентів виконується в окремому ізольованому воркері (Sandbox Worker). Усі дії користувачів та операції з оцінками фіксуються в журналі аудиту.

На першому етапі було виділено основні активи системи та оцінено їхню цінність за властивостями безпеки: конфіденційність (К), цілісність (Ц) та доступність (Д) за шкалою Н (низька), С (середня), В (висока). Результати інвентаризації наведено в таблиці 1.1.

Таблиця 1.1 – Активи системи та оцінка їхньої цінності

№	Актив	Тип	Цінність (К/Ц/Д)	Призначення та обґрунтування
А-01	Студентські роботи (код)	Дані (файли)	В / В / С	Захист від несанкціонованого доступу інших студентів до дедлайну та від зміни після здачі.
А-02	Оцінки та відомості	Дані (записи БД)	С / В / В	Академічні бали. Неприпустима зміна після виставлення; захист приватності оцінок.
А-03	Журнал подій аудиту	Журнал (WORM)	С / В / В	Ключовий актив для захисту від відмови від авторства (Repudiation). Таймстемпи, геші робіт.
А-04	Закриті тестові набори	Конфігурація	В / В / С	Тести викладача. Витік дозволяє підігнати рішення без реального виконання завдання.
А-05	Облікові дані та токени	Автентифікація	В / В / В	Парольні геші, JWT-сесії, службові ключі доступу до сервісів.
А-06	Ресурси пісочниці	Інфраструктура	Н / В / В	CPU/RAM воркера. Захист від DoS, нескінченних циклів та криптомайнінгу.

Наступним кроком було спроєктовано діаграму потоків даних (DFD). У системі виділено три межі довіри (Trust Boundaries): межа зовнішньої мережі Інтернет (ТВ1), що відокремлює клієнтські пристрої від вебсервера; межа збереження даних (ТВ2), яка захищає реляційну БД та сховище аудиту; та межа пісочниці перевірки (ТВ3), яка ізолює виконання потенційно шкідливого студентського коду у воркері від основної інфраструктури. На рисунку 1.1 наведено діаграму потоків даних системи.

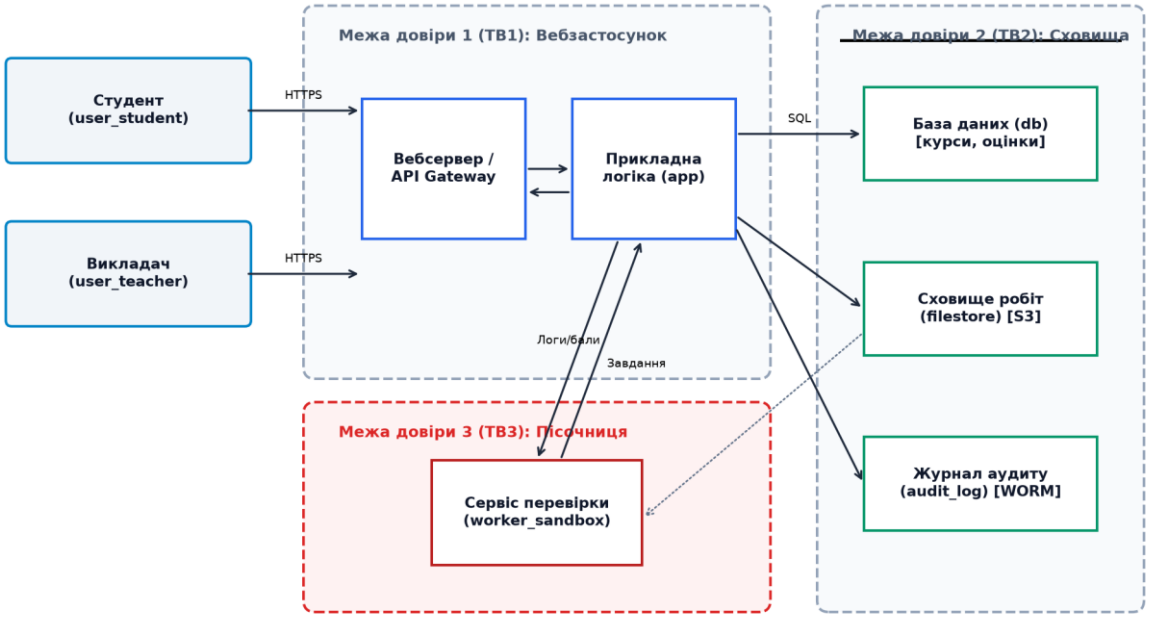


Рисунок 1.1 – Діаграма потоків даних (DFD) системи

Для виявлення потенційних загроз було застосовано методологію STRIDE-per-element до кожного елемента та потоку діаграми. Згідно з варіантом 18 пріоритетною категорією є відмова від авторства (Repudiation). Всього було сформовано 14 загроз, з яких 6 (42.9%) належать до пріоритетної категорії, що забезпечує її домінування над іншими. Перелік виявлених загроз зведено в таблицю 1.2.

Таблиця 1.2 – Перелік загроз за методологією STRIDE

№	Елемент / потік	STRIDE	Опис загрози	Порушена властивість
T-01	app	Repudiation	Студент заперечує факт здачі неякісного або плагійованого коду без надійного хешування та підпису квитанції.	Неспростовність
T-02	Потік 1	Repudiation	Студент заперечує порушення дедлайну, посилаючись на десинхронізацію локального часу клієнта без RFC 3161.	Неспростовність
T-03	app	Repudiation	Викладач заперечує факт зниження оцінки або ручної зміни балів без персоналізованого аудиту дій.	Неспростовність
T-04	audit_log	Repudiation	Несанкціоноване видалення або модифікація записів журналу аудиту зловмисником без WORM-захисту.	Неспростовність
T-05	worker	Repudiation	Студент заперечує спробу деструктивного	Неспростовність

			впливу на воркер через відсутність фіксації системних викликів.	
T-06	app	Repudiation	Відмова викладача від авторства зміни дедлайнів чи тестів курсу заднім числом за відсутності логування змін.	Неспростовність
T-07	Потік 1	Spoofing	Спуфінг облікового запису студента шляхом перехоплення сесійного cookie без прапорця HttpOnly.	Автентичність
T-08	filestore	Tampering	Підміна файлу розв'язку студента безпосередньо у сховищі до моменту запуску перевірки у воркері.	Цілісність
T-09	app	Tampering	SQL-ін'єкція у форму фільтрації подань, що веде до масової несанкціонованої модифікації оцінок у БД.	Цілісність
T-10	filestore	Info Disclosure	Витік закритих тестів та правильних рішень завдань через IDOR-вразливість у сховищі файлів.	Конфіденційність
T-11	worker	Denial of Service	Вичерпання пам'яті та процесорного часу (fork bomb) через відсутність cgroups/ulimit у пісочниці.	Доступність
T-12	worker	Elev. of Privilege	Втеча з контейнера перевірки (Container Escape) та отримання root-доступу на хост-сервері.	Авторизація
T-13	web	Elev. of Privilege	Підвищення прав студента до викладача шляхом зміни ролі у непідписаному JWT-токені (alg: none).	Авторизація
T-14	Потік 1	Info Disclosure	Перехоплення сесійних токенів та коду робіт через передачу трафіку відкритим HTTP без HSTS.	Конфіденційність

Для кількісного оцінювання ризиків було застосовано метрику CVSS v3.1. Базові оцінки було розраховано за допомогою наданого калькулятора cvss.py та автоматизовано скриптом scoring.py. У табл. 1.3 наведено вектори CVSS, розраховані базові оцінки, якісні показники ймовірності, впливу та рівні ризику.

Таблиця 1.3 – Оцінювання ризиків за базовими метриками CVSS v3.1

№	Вектор CVSS v3.1	Бал	Імовірність	Вплив	Ранг ризику

T-01	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3	Середня	Низький	Середній
T-02	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3	Висока	Низький	Середній
T-03	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3	Низька	Середній	Середній
T-04	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H	8.1	Низька	Критичний	Високий
T-05	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L	5.4	Середня	Середній	Середній
T-06	CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:N	2.7	Низька	Низький	Низький
T-07	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	8.1	Середня	Високий	Високий
T-08	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N	6.5	Низька	Високий	Середній
T-09	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	8.8	Середня	Катастрофічний	Високий
T-10	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	6.5	Середня	Середній	Середній
T-11	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H	6.5	Висока	Середній	Середній
T-12	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H	9.9	Середня	Катастрофічний	Критичний
T-13	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	8.8	Низька	Катастрофічний	Високий
T-14	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N	5.3	Низька	Високий	Середній

На рисунку 1.2 показано результат роботи скрипта scoring.py у терміналі.

```
D:\Studying\Семестр 7\БПЗ\Lab1\звіт_пр1> python scoring.py
T-01: 4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N)
T-02: 4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N)
T-03: 4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N)
T-04: 8.1 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H)
T-05: 5.4 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L)
T-06: 2.7 (CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:N)
T-07: 8.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N)
T-08: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N)
T-09: 8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
T-10: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)
T-11: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)
T-12: 9.9 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)
T-13: 8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
T-14: 5.3 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N)
```

Рисунок 1.2 – Результат розрахунку оцінок CVSS скриптом scoring.py

Найкритичнішою загрозою за базовою оцінкою є T-12 (втеча з пісочниці перевірки на хост-сервер) із балом 9.9 (рівень Critical). Для цієї загрози було побудовано дерево атак (Attack Tree), яке деталізує можливі кроки зловмисника через логічні зв'язки AND та OR. На рисунку 1.3 показано побудоване дерево атак.

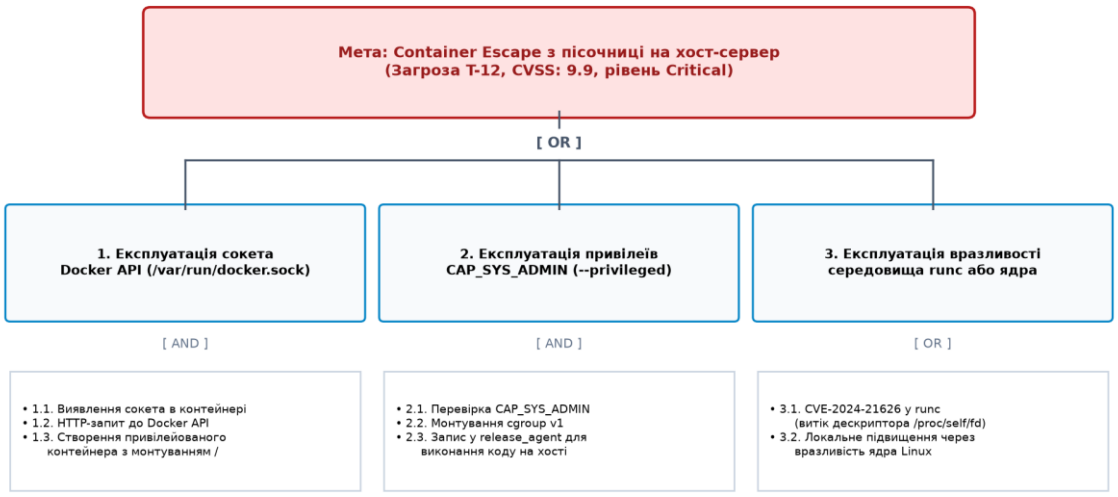


Рисунок 1.3 – Дерево атак для загрози T-12

На основі проведеного аналізу було сформовано реєстр ризиків із визначенням рішень (усунути, зменшити, передати або прийняти), технічних контрзаходів та оцінкою залишкового ризику. Дані наведено в таблиці 1.4.

Таблиця 1.4 – Реєстр ризиків та контрзаходи

№	Ризик	Рішення	Контрзахід	Залишковий ризик
Т-12	Втеча з контейнера воркера (Container Escape)	Усунути / Зменшити	Ізоляція через gVisor/Kata Containers, запуск non-root, заборона docker.sock, скидання capabilities (--cap-drop=ALL).	Низький (2.1)
Т-09	Масова зміна оцінок через SQL-ін'єкцію	Усунути	Використання виключно параметризованих підготовлених виразів (Prepared Statements) або ORM із типізацією.	Немає (0.0)
Т-13	Підвищення привілеїв через непідписаний JWT	Усунути	Білий список алгоритмів підпису (RS256/EdDSA), заборона alg:none, перевірка терміну дії токенів на API Gateway.	Низький (1.5)
Т-04	Знищення/модифікація журналу аудиту дій	Зменшити / Передати	WORM-сховище (Write Once Read Many), криптографічне хешування ланцюжків записів (hash-chain), експорт на виділений сервер.	Низький (2.3)
Т-07	Спуфінг сесії студента через крадіжку cookie	Зменшити	Прапорці HttpOnly, Secure, SameSite=Strict для кук сесії; прив'язка сесії до IP-підмережі та тайм-аут неактивності 30 хв.	Низький (2.0)
Т-01	Заперечення студентом факту подання роботи	Зменшити	Фіксація SHA-256 гешу коду під час завантаження, видача цифрової квитанції подання та дублювання в незмінний аудит.	Низький (1.8)
Т-02	Заперечення прострочення дедлайну	Прийняти / Зменшити	Серверний час NTP як єдине джерело правди; автоматичний пільговий grace period 5 хвилин на мережеві затримки.	Низький (1.5)
Т-03	Заперечення викладачем зниження оцінки	Зменшити	Версіонування записів балів: кожна зміна створює новий рядок із зазначенням ID викладача, часу та обов'язкового коментаря.	Низький (1.5)
Т-05	Заперечення спроб деструктивних дій у воркері	Зменшити	eBPF-моніторинг системних викликів контейнера (Falco), збереження повного потоку stderr та коду виходу процесу.	Низький (1.8)
Т-06	Відмова від авторства зміни дедлайнів курсу	Прийняти	Логування змін конфігурації в журналі застосунку. Приймається, оскільки зміни зазвичай ідуть на користь студентам.	Низький (1.2)
Т-08	Підміна файлу розв'язку у сховищі	Зменшити	Контентно-адресоване сховище (ім'я = SHA-256); верифікація контрольної суми перед запуском у пісочницю.	Низький (1.5)

T-10	Витік закритих тестів через IDOR	Зменшити	Зберігання закритих тестів у захищеній приватній зоні; доступ виключно за сертифікатом воркера (mTLS).	Низький (1.8)
T-11	Зависання воркера через fork-бомбу	Зменшити	Обмеження cgroups v2 (pids.max=32, memory.max=256M, cpu.max=50%), жорсткий таймаут виконання 10 секунд.	Низький (2.0)
T-14	Перехоплення сесійних даних у відкритій мережі	Зменшити	Примусовий редирект HTTP -> HTTPS, заголовок HSTS, відключення застарілих версій TLS нижче 1.3.	Низький (1.2)

Аналіз отриманих результатів:

1. Розподіл загроз за категоріями STRIDE: Категорія Repudiation склала 6 загроз із 14 (42.9%), Tampering – 2 (14.3%), Information Disclosure – 2 (14.3%), Elevation of Privilege – 2 (14.3%), Spoofing – 1 (7.1%), Denial of Service – 1 (7.1%). Гіпотеза варіанта 18 підтвердилася: для платформи дистанційного навчання із завантаженням та оцінюванням робіт захист від відмови від авторства є критичним, оскільки постійно виникають апеляції щодо дедлайнів, авторства рішень і виставлених балів.

2. Найвразливіші компоненти: Найбільше загроз породжують процес пісочниці worker (знаходиться на межі ТВ3 і виконує недовірений код студентів) та процес app (обробляє операції зміни стану).

3. Обґрунтування найвищої оцінки CVSS: Загроза T-12 отримала бал 9.9 завдяки зміні області (Scope: Changed, S:C) – вихід з контейнера дає повний контроль над хостом, максимальному руйнівному впливу (C:H, I:H, A:H) та низьким вимогам до зловмисника (достатньо облікового запису студента PR:L без взаємодії з користувачем UI:N).

4. Найефективніший контрзахід: Впровадження мікровіртуалізації на рівні ядра (gVisor/Kata) разом із відкиданням capabilities повністю блокує всі гілки дерева атак T-12. Для категорії Repudiation єдиний контрзахід – WORM-аудит із SHA-256 квитанціями – одночасно закриває загрози T-01, T-02, T-03, T-04, T-05.

5. Обґрунтування прийняття ризику: Стратегію «прийняти» обрано для загроз T-02 (незначна десинхронізація годинника студента, що компенсується 5-

хвилинним grace period) та T-06 (зміна дедлайну викладачем). Впровадження інфраструктури КЕП для кожного студента не є економічно обґрунтованим.

Контрольні запитання.

1. Чим межа довіри відрізняється від межі мережевого сегмента? Наведіть приклад із вашої діаграми.

Межа мережевого сегмента є фізичним або логічним розділенням мережі (наприклад, окрема підмережа чи VLAN). Межа довіри (Trust Boundary) – це концептуальна межа, на якій змінюється рівень довіри або привілеїв суб'єктів. Приклад з діаграми: межа TB3 між процесом app та процесом worker: вони можуть знаходитися в одній мережі, але worker виконує недовірений сторонній код, тому йому надано ізольований мінімальний рівень довіри.

2. Які чотири типи елементів має діаграма потоків даних і як вони позначаються?

1) Зовнішня сутність (External entity) – прямокутник або овал; 2) Процес (Process) – коло або прямокутник із закругленими кутами; 3) Сховище даних (Data store) – дві паралельні лінії або циліндр; 4) Потік даних (Data flow) – спрямована лінія зі стрілкою.

3. Розшифруйте абревіатуру STRIDE та вкажіть властивість безпеки, яку порушує кожна категорія.

S – Spoofing (спуфінг) -> порушує автентичність;
T – Tampering (підміна даних) -> порушує цілісність;
R – Repudiation (відмова від авторства) -> порушує неспростовність;
I – Information Disclosure (розкриття інформації) -> порушує конфіденційність;
D – Denial of Service (відмова в обслуговуванні) -> порушує доступність;
E – Elevation of Privilege (підвищення привілеїв) -> порушує авторизацію.

4. Чому до зовнішньої сутності не застосовують категорії Tampering і Denial of service, а до процесу – усі шість?

Зовнішня сутність (користувач, стороння система) знаходиться поза межами контролю програмного забезпечення, тому система не контролює її внутрішню цілісність чи працездатність – її можна лише автентифікувати або зафіксувати її дію. Процес повністю контролюється системою, тому для нього можливі всі шість категорій загроз.

5. Які метрики входять до базового вектора CVSS? Що означають значення S:U і S:C?

До базового вектора входять: AV (вектор атаки), AC (складність), PR (потрібні привілеї), UI (взаємодія з користувачем), S (область), C (вплив на конфіденційність), I (цілісність), A (доступність). Значення S:U (Scope: Unchanged) означає, що вразливий і вражений компоненти мають одну область повноважень. Значення S:C (Scope: Changed) означає, що успішна атака дозволяє скомпрометувати інший компонент із власною політикою безпеки (наприклад, вихід із контейнера на хост).

6. Обчисліть подумки, який рівень відповідає базовій оцінці 6,5, і перевірте результат калькулятором для вектора CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N.

Діапазон оцінок 4.0–6.9 за класифікацією CVSS відповідає рівню Середній (Medium). Перевірка: підстановка вектора у калькулятор cvss.py дає результат рівно 6.5 (Medium).

7. Як зміниться базова оцінка загрози, якщо для експлуатації почнуть вимагатися привілеї адміністратора (PR змінюється з N на H)? Поясніть напрям зміни.

Базова оцінка суттєво зменшиться. Множник метрики PR зменшується з 0.85 (PR:N) до 0.27 (PR:H), оскільки вимога привілеїв адміністратора суттєво звужує коло потенційних зловмисників та ускладнює проведення атаки.

8. Що станеться з оцінкою, якщо область (Scope) зміниться з U на C за незмінних інших метрик? Чому специфікація вводить окрему формулу для зміненої області?

Оцінка зросте. Специфікація CVSS v3.1 запроваджує для зміненої області окрему формулу з підвищеним коефіцієнтом масштабування, оскільки компрометація іншого компонента безпеки створює набагато більшу загрозу для інфраструктури.

9. Чим вузол AND у дереві атак відрізняється від вузла OR з погляду вибору контрзаходу? Який тип вузла вигідніший для захисника?

Вузол AND вимагає успішного виконання всіх дочірніх дій одночасно, а для OR достатньо хоча б однієї. Для захисника вигідніший вузол AND, оскільки для нейтралізації загрози достатньо заблокувати хоча б одну піддію у гілці.

10. Порівняйте стратегії «зменшити» та «передати» ризик. Наведіть по одному прикладу доречного застосування кожної для вашої системи.

«Зменшити» – це впровадження технічних заходів для зниження ймовірності чи впливу загрози (наприклад, використання параметризованих SQL-виразів проти T-09). «Передати» – це делегування ризику третій стороні (наприклад, делегування зберігання журналів аудиту T-04 хмарному сервісу з гарантією WORM або використання зовнішньої OAuth-автентифікації).

11. Що таке залишковий ризик і чому він рідко дорівнює нулю навіть після впровадження контрзаходу?

Залишковий ризик – це рівень ризику, що залишається після впровадження контрзаходу. Він рідко дорівнює нулю через можливість помилок у конфігурації, наявність невідомих вразливостей (0-day) або людський фактор.

12. Запропонуйте контрзахід, який одночасно знижує ризик двох різних загроз із вашої таблиці STRIDE, і поясніть механізм.

Впровадження незмінного захищеного журналу аудиту (WORM) із криптографічними квитанціями SHA-256. Механізм: фіксація гешу коду під час завантаження унеможливлює відмову студента від авторства (T-01), а захист від модифікації запобігає видаленню записів зловмисником (T-04).

13. Як зміниться перелік пріоритетних загроз, якщо цінність активу «журнал подій» підвищити з середньої до високої за цілісністю? Які категорії STRIDE стануть важливішими?

Загрози, спрямовані на журнал подій, отримають найвищий пріоритет. Важливішими стануть категорії Tampering (несанкціоноване редагування записів логу) та Repudiation (спроби заперечення дій).

14. Чому модель загроз будують до написання коду, а не після? Обґрунтуйте з погляду вартості усунення дефекту.

Модель загроз будують на етапі проєктування (Secure SDLC), оскільки усунення архітектурних дефектів на цьому етапі коштує в десятки разів дешевше, ніж переписування вже готового коду, тестування та повторне розгортання після виявлення вразливостей у продакшені.

Програмні коди.

Файл scoring.py

```
# scoring.py — оцінювання переліку загроз для варіанта 18
from cvss import base_score

threats = {
    "T-01": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N",
    "T-02": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N",
    "T-03": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N",
    "T-04": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H",
    "T-05": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L",
    "T-06": "CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:L/A:N",
    "T-07": "CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N",
    "T-08": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N",
    "T-09": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",
    "T-10": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N",
    "T-11": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H",
    "T-12": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H",
    "T-13": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",
    "T-14": "CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N",
}

for tid, vector in threats.items():
    print(f"{tid}: {base_score(vector)} ({vector})")
```

Файл dfd.mmd

```
flowchart LR
    user_student([Студент]):::ext
    user_teacher([Викладач]):::ext

    subgraph TB1 [Межа довіри 1: Вебзастосунок та API]
        web[Вебсервер / API Gateway]
        app[Прикладна логіка платформи]
```

```
end

subgraph TB2 [Межа довіри 2: Сховища даних системи]
    db[(База даних курсів та оцінок)]
    filestore[(Сховище файлів робіт S3/NFS)]
    audit_log[(Незмінний журнал аудиту WORM)]
end

subgraph TB3 [Межа довіри 3: Ізольована пісочниця перевірки]
    worker[Сервіс автоперевірки / Sandbox Worker]
end

user_student -->|1. Подання розв'язку через HTTPS| web
user_teacher -->|2. Виставлення оцінок та налаштування дедлайнів HTTPS| web
web -->|3. Авторизовані REST виклики| app
app -->|4. Запис і читання оцінок та курсів через SQL| db
db -->|5. Оцінки та метадані| app
app -->|6. Збереження артефактів робіт| filestore
app -->|7. Невідмовна фіксація подій та гешів здач| audit_log
app -->|8. Черга завдань автоперевірки| worker
filestore -.->|9. Завантаження коду в пісочницю| worker
worker -->|10. Результати тестування, метрики та stderr| app
app -->|11. Оновлений стан і звіти| web
web -->|12. Відображення результату студенту| user_student
web -->|13. Відображення відомостей викладачу| user_teacher
classDef ext fill:#f2f4f8,stroke:#1e293b,stroke-width:2px;
```

Висновок.

У ході виконання першої лабораторної роботи було успішно побудовано та проаналізовано модель загроз для платформи онлайн-курсів із перевіркою завдань відповідно до варіанта 18. Під час аналізу системи було виділено 6 ключових активів та розроблено діаграму потоків даних (DFD) із трьома межами довіри, що відокремлюють зовнішніх клієнтів, внутрішні сховища та ізольоване середовище тестування коду. За методологією STRIDE-per-element було ідентифіковано 14 загроз інформаційній безпеці, з яких 6 (42.9%) належать до пріоритетної категорії відмови від авторства (Repudiation), що підтвердило гіпотезу про критичність цієї категорії для дистанційних освітніх платформ. За допомогою метрики CVSS v3.1 було проведено кількісну оцінку загроз та виявлено 5 загроз високого та критичного рівнів ризику (бал ≥ 7.0), серед яких найбільш небезпечною визначено загрозу втечі з пісочниці перевірки на хост-сервер (T-12, бал 9.9). Для цієї загрози було побудовано дерево атак із логікою AND/OR та обґрунтовано впровадження мікровіртуалізації на базі ядра (gVisor) та відкидання привілеїв capabilities. Сформований реєстр ризиків забезпечив визначення стратегій обробки для всіх загроз, а застосування незмінного журналу аудиту (WORM) із криптографічними

квитанціями подання дозволило ефективно мінімізувати ризики відмови від авторства. Здобуті результати підтверджують успішне виконання всіх поставлених завдань лабораторної роботи.